



PROCEDIMIENTO DE GESTIÓN DE RIESGOS DE LA SEGURIDAD DE LA INFORMACIÓN

Sistema de Gestión de Seguridad de la Información – Nivel Central



Código	PROS-NC- 006
Versión oficial:	V 1.0
Fecha de la versión:	junio 2023
Elaborado por:	Pablo Fabres
Revisado por	Jose Villa
Aprobado por:	Jorge Herrera



CONTENIDO

1	PROPÓSITO.....	3
2	ALCANCE.....	3
3	TERMINOLOGÍA	3
4	DOCUMENTOS APLICABLES.....	4
5	ROLES Y RESPONSABILIDADES	4
6	PROCEDIMIENTO	4
6.1	CONDICIONES GENERALES	4
6.2	FLUJO DEL PROCESO	5
6.3	ESTABLECIMIENTO DEL CONTEXTO.....	6
6.4	VALORIZACION DEL RIESGO	6
6.5	TRATAMIENTO DEL RIESGO.....	17
6.6	ACEPTACIÓN DEL RIESGO	17
6.7	COMUNICACIÓN DE LOS RIESGOS	20
6.8	MONITOREO Y REVISIÓN	20
6.9	VALIDACIÓN Y TRATAMIENTO.....	20
7	REGISTROS.....	21
8	DIFUSION.....	21
9	REVISION Y MEDICION	21
10	CONTROL DE VERSIONES	21
11	REFERENCIAS	21
12	ANEXOS	22

1 PROPÓSITO

El propósito del presente documento es establecer un procedimiento sobre la gestión de riesgos del sistema de gestión de seguridad de la información (SGSI), siguiendo la estructura de tratamiento lineada por la política de gestión de riesgos de seguridad de la información, basado en la normativa ISO.

En la determinación de los riesgos se deberá identificar, cuantificar y priorizar los riesgos de acuerdo a criterios de aceptación y objetivos relevantes para la organización. Como resultado de este proceso, se determinarán las acciones apropiadas de acuerdo con las prioridades de la organización, a través de la implementación de controles de seguridad que tendrán como objetivo protegerse de los riesgos identificados.

2 ALCANCE

Este procedimiento aplica a todos los activos de información e incluso aquellos gestionados mediante contratos con terceros.

Aplica a todos los funcionarios (planta, contrata, reemplazos y suplencias), personal a honorarios y terceros (proveedores) que presten servicios para las subsecretarías de salud pública y redes asistenciales.

Abarca los siguientes controles definidos en la norma NCh-ISO 27001.Of2013:

- A.05.01.01 Políticas para la seguridad de la información.
- A.05.01.02 Roles y responsabilidades en seguridad de la información.
- A.18.01.02 Revisión de las políticas de seguridad de la información

3 TERMINOLOGÍA

Para facilitar el proceso de análisis y valoración de los riesgos es importante entender algunos conceptos básicos:

- **Amenaza:** causa potencial de un incidente no deseado, que puede resultar en un daño a un sistema, persona u organización.
- **Apetito del Riesgo:** Corresponde a la definición de la institución para determinar si el riesgo y su severidad, se encuentra dentro de sus límites aceptados para su manejo.
- **Confidencialidad:** La información solo tiene que ser accesible o divulgada a aquellos que están autorizados.
- **Disponibilidad:** La información debe estar siempre accesible para aquellos que estén autorizados.
- **Impacto:** es la consecuencia de la materialización de una amenaza sobre un activo. El costo para la institución de un incidente de la escala que sea, que puede o no ser medido en términos estrictamente financieros (ejem.: pérdida de reputación, implicaciones legales, entre otros).
- **Integridad:** La información debe permanecer correcta (integridad de datos) y como el emisor la originó (integridad de fuente) sin manipulaciones por terceros.
- **Mapa de Calor:** Corresponde a una técnica de medición de valores, por medio de la presentación de colores bidimensional, esto con el objeto de observar relevancia a partir de los valores entregados al mapa.
- **Riesgo Inherente:** Toda actividad, solo por el hecho de ser realizada, en sí tiene asociado un riesgo implícito (es decir, antes de aplicar controles). Es también llamado riesgo puro.
- **Riesgo residual:** El riesgo que permanece tras el tratamiento del riesgo.
- **Riesgo:** Posibilidad de que una amenaza concreta pueda explotar una vulnerabilidad para causar una pérdida o daño en un activo de información. Suele considerarse como una combinación de la probabilidad de un evento y sus consecuencias.

- **Vulnerabilidad:** Debilidad de un activo o control que puede ser explotada por una o más amenazas.

4 DOCUMENTOS APLICABLES

Dentro de los documentos normativos aplicables, y lineamientos institucionales, podemos referenciar los siguientes:

- Norma NCh-ISO 31000:2018 sobre directrices para la gestión de riesgos.
- Norma NCh-ISO/IEC 27005:2020 sobre las tecnologías de información, y la gestión del riesgo de seguridad de la información.
- Norma NCh-ISO/IEC 27001:2020, puntos 6.1.2 de evaluación de riesgo de la seguridad de la información, y el punto 6.1.3 de tratamiento de riesgo de la seguridad de la información.
- El Marco Jurídico referido a los Sistemas de Seguridad de la Información (SSI), publicado en el portal del CSIRT del Ministerio del Interior.
 - Decretos Supremos y Normas Internacionales de Seguridad de la Información y Ciberseguridad:
 - Leyes relacionadas
- **Documentos Relacionados**
 - Política General de Seguridad de la Información [1].
 - Política de Gestión de Riesgos de Seguridad de la Información [2].

5 ROLES Y RESPONSABILIDADES

- **Nivel Directivo:** responsable de generar las condiciones adecuadas para la ejecución y comunicación de presente procedimiento. Además, responsable de asignar los recursos necesarios para implementar, mantener el proceso de gestión de riesgos y tratamiento.
- **Comité de Seguridad de la Información:** El Comité de Seguridad de la Información (CSI) tiene la responsabilidad de supervisar y respaldar la gestión de riesgos de seguridad de la información del Ministerio. Esto incluye la revisión regular de la efectividad de los procedimientos relacionados con la gestión de riesgos.
- **Encargado de Seguridad de la Información / Encargado de Ciberseguridad:** Velar por la aplicación del presente procedimiento y brindar asesoramiento en la identificación de las amenazas que pueden afectar a los activos de información y las vulnerabilidades que propician las mismas e informar al Comité de Seguridad de la Información sobre los resultados de la evaluación de los riesgos. Es responsable, en conjunto con los propietarios de los activos de información, por la definición de las acciones de tratamiento de los riesgos de seguridad de la información.
- **Los dueños de los activos de información:** Propietarios de los activos tendrán que dar aplicación al presente procedimiento e identificar, estimar y valorar los riesgos identificados. Es responsable, en conjunto con el responsable de seguridad de la información, por la definición de las acciones de tratamiento de los riesgos de seguridad de la información.

6 PROCEDIMIENTO

6.1 CONDICIONES GENERALES

La gestión del riesgo de seguridad de la información debe ser una parte integral de todas las actividades de gestión de seguridad de la información y se debe aplicar tanto a la implementación como a la operación en curso de un SGSI.

Las actividades para la gestión del riesgo de la seguridad de la información:

- Establecimiento del contexto
- Valoración del riesgo
- Tratamiento del riesgo
- Aceptación del riesgo
- Comunicación del riesgo
- Monitoreo y revisión del riesgo

A continuación, se describen las actividades que se desarrollan para realizar la identificación y valoración de los riesgos de seguridad de la información.

PROCESO PARA LA GESTIÓN DEL RIESGO DE SEGURIDAD DE LA INFORMACIÓN	
ACTIVIDADES	PASO
Establecimiento del contexto	1. Consideraciones Generales - Levantamiento de información inicial
	2. Establecer criterios básicos para la Gestión del Riesgo
	3. Definir alcance y límites de la Gestión del Riesgo.
Valoración del Riesgo	4. Identificar Activos de Información
	5. Identificar las amenazas y las vulnerabilidades
	6. Identificar los controles existentes
	7. Identificar consecuencias
	8. Valorar las consecuencias
	9. Valorar los incidentes
	10. Determinar el nivel de estimación del riesgo
	11. Evaluar el riesgo
Tratamiento del Riesgo	12. Selección de controles
Aceptación del Riesgo	13. Aceptar el riesgo
Comunicación del Riesgo	14. Comunicar el riesgo
Monitoreo y Revisión del Riesgo	15. Monitorear y revisar los riesgos

6.2 FLUJO DEL PROCESO

Este flujo se centra en establecer un enfoque sistemático y estructurado para identificar, evaluar y tratar los riesgos de seguridad de la información en una organización. Aquí está el proceso en términos generales:

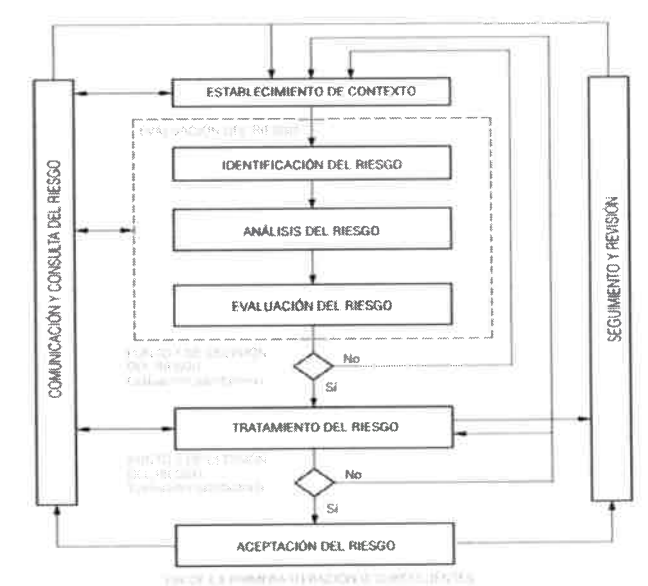


Figura 2: Proceso de Gestión de Riesgo de Seguridad de la Información¹

¹ Imagen Norma NCh-ISO/IEC 27005:2018, Gestión del Riesgo de Seguridad de la Información – Visión general del proceso de gestión de riesgo de seguridad de la información.

6.3 ESTABLECIMIENTO DEL CONTEXTO

Se debe establecer el contexto para la gestión del riesgo de la seguridad de la información, lo cual implica establecer los criterios básicos necesarios para la gestión del riesgo de la seguridad de la información: definir el alcance y los límites, establecer una organización adecuada que opere la gestión del riesgo de la seguridad de la información.

6.3.1.1 Criterios básicos

Dependiendo del alcance y los objetivos de la gestión del riesgo, se pueden aplicar diferentes enfoques de criterios:

Se debe seleccionar o desarrollar un enfoque adecuado para la gestión del riesgo que aborde los criterios básicos tales como: criterios de evaluación del riesgo, criterios de impacto, criterios de aceptación del riesgo, entre otros.

- Criterios de identificación del riesgo: Es recomendable considerar los activos de información con el valor de impacto alto para el proceso de evaluación del riesgo.
- Criterios de evaluación del riesgo: Es recomendable desarrollar criterios para la evaluación del riesgo con el fin de determinar el riesgo de la seguridad de la información de la institución.
- Criterios de impacto: Es recomendable desarrollar criterios de impacto del riesgo y especificarlos en términos del grado de daño o de los costos para la organización, causados por un evento de seguridad de la información.
- Criterios de la aceptación del riesgo: Es recomendable desarrollar y especificar criterios de aceptación del riesgo. Estos criterios dependen con frecuencia de las políticas, metas, objetivos de la institución y de las partes interesadas.

6.3.1.2 Alcance y límites

Es necesario definir el alcance del proceso de gestión del riesgo de la seguridad de la información, con el fin de garantizar que todos los activos relevantes se toman en consideración en la valoración del riesgo. Además, es necesario identificar los límites para abordar aquellos riesgos que se pueden presentar al establecer estos límites.

- Para establecer la comprensión de la organización, sus contextos internos, externos y partes interesadas, se podrán utilizar metodologías del tipo análisis FODA (fuerza, oportunidad, debilidad y amenaza) o análisis PESTEL (política, economía, social, tecnología, ecológica/medio ambiente y legal) u otra que se considere pertinente, de forma que incluya la comprensión de los entornos definidos para el alcance.
- La organización y las responsabilidades en el proceso de gestión del riesgo y estará radicada en el Comité de Seguridad de la Información y el Encargado de Seguridad de la Información y Ciberseguridad de la institución, a través del acto administrativo correspondiente.

6.4 VALORIZACION DEL RIESGO

A continuación, se presenta una estructura lineal para llegar a un pleno conocimiento de materias importantes para la valorización del riesgo, comenzando por la identificación de los activos de información sobre los cuales vamos a inferir determinados riesgos.

6.4.1.1 Identificación de Activos de Información.

La identificación de activos de información es el punto inicial para la gestión de riesgo, ya que es sobre ellos a los que evaluaremos en cuenta a riesgos, según su criticidad e

importancia para la institución, su identificación es indispensable para todo proceso de gestión de riesgos.

- Clasificación de los activos, según se establece en las siguientes categorías:

Tipo	Descripción
Instalaciones	En esta categoría están los lugares donde se hospedan los sistemas de información y comunicaciones.
Equipamiento auxiliar	En esta categoría se consideran otros equipos que sirven de soporte a los sistemas de información, sin estar directamente relacionados con datos.
Hardware	Dícese de bienes materiales, físicos, destinados a soportar directa o indirectamente los servicios que presta la organización, siendo pues depositarios temporales o permanentes de los datos, soporte de ejecución de las aplicaciones informáticas o responsables del procesado o la transmisión de datos.
Software	Con múltiples denominaciones (programas, aplicativos, desarrollos, etc.) esta categoría se refiere a tareas que han sido automatizadas para su desempeño por un equipo informático. Las aplicaciones gestionan, analizan y transforman los datos permitiendo la explotación de la información para la prestación de los servicios.
Soportes de información	En esta categoría se consideran dispositivos físicos que permiten almacenar información de forma permanente o, al menos, durante largos periodos de tiempo.
Datos/ información	Elementos de información que, de forma singular o agrupados de alguna forma, representan el conocimiento que se tiene de algo.
Servicios	Función que satisface una necesidad de los usuarios (del servicio). Para la prestación de un servicio se requieren una serie de medios. Los servicios aparecen como activos de un análisis de riesgos bien como servicios finales (prestados por la empresa a terceros), bien como servicios instrumentales (donde tanto los usuarios como los medios son propios), bien como servicios contratados (a otra organización que los proporciona con sus propios medios).
Personal	En esta categoría aparecen las personas relacionadas con los sistemas de información.

- Se debe identificar al propietario de cada activo, para asignarle la responsabilidad y rendición de cuentas sobre éste. El propietario del activo puede no tener derechos de propiedad sobre el activo, pero tiene la responsabilidad de su producción, desarrollo, mantenimiento, uso y seguridad, según corresponda.
- De esta etapa se genera una lista de los activos que van a estar sometidos a gestión del riesgo, y una lista de los procesos del negocio relacionados con los activos y su importancia.

Por lo tanto, la estructura de la identificación de activos debe contener los siguientes apartados y campos.

----- **Identificación del Proceso** -----

- Id. Proceso: Identificador del proceso vinculado al cumplimiento de objetivos estratégicos.
- Proceso: Nombre del proceso vinculado al cumplimiento de objetivos estratégicos.

- Sistema de Información: Nombre del sistema de información al cual pertenece el activo de información.

----- **Identificación del Activo** -----

- Nombre Activo: Nombre del activo de información.
- Descripción: Descripción del activo de información.
- Responsable del Activo de Información: Corresponde al cargo del funcionario o persona, responsable del activo.
- Tipo de Activo: Corresponde a la clasificación descrita en tabla.
- Cod. Tipo: Corresponde al código del tipo de activo, este es un identificar sencillo de 3 caracteres, lo que se deben corresponder con en nombre del tipo de activo, por ejemplo, para servicio, puede corresponder SER, para software, SOF.
- Número: Este es un número correlativo para asignación del activo de información.
- Id. Activo: El Id del activo corresponde a su código identificador, que para este caso sería compuesto por 3 secciones, la primera fija como activo (ACT), luego el tipo de activo y finalmente su número, un ejemplo de Id. Activo puede ser "ACT-SER-0021".
- Ubicación: Responde al sitio o lugar donde se encuentra el activo.

6.4.1.2 Valoración de los activos / Ponderación de la criticidad de activos

La ponderación de activos es una etapa en la que participan las unidades del negocio involucradas con el fin de determinar en términos cualitativos la criticidad de los distintos activos.

La ponderación se realiza en términos de “alto, medio o bajo” donde se debe asignar un valor cuantitativo a cada valor cualitativo. La valorización del activo será realizada según los atributos de la información (Confidencialidad, Integridad y Disponibilidad), para ello se deben utilizar las siguientes herramientas de valorización por atributo:

Valoración del impacto en términos de la perdida de la confidencialidad:

Confidencialidad	Criterio
Alto (3)	La divulgación no autorizada de la información tiene un efecto crítico para la institución. Ej. Divulgación de información confidencial o sensible
Medio (2)	La divulgación no autorizada de la información tiene un efecto limitado para la institución. Ej. Divulgación de información de uso interno.
Bajo (1)	La divulgación de la información no tiene ningún efecto para la institución. Ej. Divulgación de información pública

Valoración del impacto en términos de la perdida de la integridad:

Integridad	Criterio
Alto (3)	La destrucción o modificación no autorizada de la información tiene un efecto severo para la institución.
Medio (2)	La destrucción o modificación no autorizada de la información tiene un efecto considerable para la institución.
Bajo (1)	La destrucción o modificación de la información tiene un efecto leve para la institución

Valoración del impacto en términos de la pérdida de la disponibilidad:

Disponibilidad	Criterio
Alto (3)	La interrupción al acceso de la información o los sistemas tienen un efecto severo para la institución.
Medio (2)	La interrupción al acceso de la información o los sistemas tienen un efecto considerable para la institución
Bajo (1)	La interrupción al acceso de la información o los sistemas tienen un efecto mínimo para la institución.

La valoración del impacto de un activo (VA), es el promedio de los valores de las tres dimensiones de la Gestión de la Seguridad de la Información:

$$VA = \frac{C + I + D}{3}$$

----- Valorización del Impacto -----

- C: En este campo se debe evaluar el atributo de la información “Confidencialidad”, según como es requerido y explicado en párrafos posteriores en el presente documento.
- D: En este campo se debe evaluar el atributo de la información “Disponibilidad”, según como es requerido y explicado en párrafos posteriores en el presente documento.
- I: En este campo se debe evaluar el atributo de la información “Integridad”, según como es requerido y explicado en párrafos posteriores en el presente documento.
- Valor del Impacto del Activo: En este campo se debe asignar el valor de la criticidad según el criterio definido en el apartado anterior.
- Nivel de Impacto (VA): Corresponde al promedio de los valores de las tres dimensiones del CID.

Ejemplo en tabla:

Valorización de los Activos de Información							
#	Nombre Activo	Tipo Activo	Ubicación	Valorización de Impacto (pérdida)			
				C	I	D	VA
1	Sistema RRHH	Lógico	CPD	3	3	2	2,66
2	Enlace Internet	Físico Lógico	CPD	1	1	1	1,00

Cabe señalar que cada activo será evaluado respecto a estos tres criterios y su promedio, posteriormente la determinación final del valor del impacto es asignada según el rango que defina la institución.

La institución podrá determinar la escala que permita determinar el criterio de criticidad del activo, como, por ejemplo:

Criterio de VA	
>= 2,5	ALTO
1,5>=><2,5	MEDIO
<1,5	BAJO

6.4.2 **Análisis y evaluación de Riesgos**

El análisis de riesgos se debe llevar a cabo siguiendo los escenarios descritos a continuación, considerando puntualmente la identificación de amenazas, vulnerabilidades y su probabilidad de materialización. Si bien el análisis del riesgo se puede llevar a cabo en variados grados de detalle, este es el proceso mínimo para su consideración.

6.4.2.1 **Identificación del riesgo**

La identificación de los riesgos busca una relación de los posibles puntos de peligro. Lo que se identifique será analizado en la siguiente etapa. Lo que no se identifique quedará como riesgo oculto o ignorado.

6.4.2.2 **El análisis de los riesgos**

Se busca calificar los riesgos identificados, bien cuantificando sus consecuencias (análisis cuantitativo), bien ordenando su importancia relativa (análisis cualitativo). De una u otra forma, como resultado del análisis tendremos una visión estructurada que nos permita centrarnos en lo más importante.

6.4.2.3 **Identificación de Amenazas.**

La identificación de amenazas se encuentra relacionada directamente con sus fuentes, por lo que se deben establecer ambos parámetros, es decir, su identificación y su fuente. Según la NCh-ISO/IEC 27.005:2020, una amenaza tiene el potencial de dañar activos de información, y pueden ser de origen natural o humano, y pueden ser producidas por accidentes o con intención deliberada, de ahí la importancia de identificar cada fuente.

La identificación de amenazas debe ser realizada agrupándolas por tipo, para posteriormente individualizarlas, el objetivo es lograr obtener un listado lo más completo posible de amenazas, incluyendo las inesperadas.

Existen diversos catálogos de amenazas que es factible utilizar, sin embargo, y como complemento de la identificación de amenazas que se pueda realizar para la institución, se deben considerar las propuestas por la NCh-ISO/IEC 27.005:2020, en su Anexo N°1 “Informativo de Ejemplos de Amenazas Típicas, donde se presenta una tabla con una lista de amenazas totalmente factibles de ser consideradas para la identificación, siendo de criterio de la persona registra las amenazas, la consideración de uso completo o parcial, el listado comentado se encuentra expuesto en el Anexo 1 del presente procedimiento.

Ejemplo identificación de amenazas

Análisis de Riesgos			
Proceso /Subproceso	# Activo	Nombre Activo	Amenaza
Infraestructura	1	Red Datos	Indisponibilidad de servicios
	2	Firewall	Acceso no deseado a activos críticos
			Indisponibilidad de servicios

Cabe señalar que cada amenaza identificada y registrada debe ser valorizada para determinar su nivel, esto con el objeto de conocer la relevancia del escenario que compromete la amenaza para el activo, a continuación, se define el método de valorización.

La identificación de amenazas debe incluir los siguientes campos.

- **Amenaza (Descripción):** Refiere a la descripción objetiva de la amenaza, indicando antecedentes relevantes de la misma, o detalles concernientes al activo relacionado.
- **Tipo Amenaza:** Se debe identificar el tipo de amenaza, como agrupador de conjunto.

- Fuente Amenaza: En este campo se debe identificar la fuente u origen de la amenaza, determinando si esta corresponde a una fuente deliberada (D), accidental (A), o del entorno (E).
- Valor Amenaza: En este campo se debe ingresar el valor cuantitativo de la amenaza para ser medida respecto de su importancia en la afección del activo evaluado.

Nivel Amenaza: Corresponde al valor cualitativo de medición de la amenaza, posteriormente se indica una escala de medición para asistir en el ingreso de esta medición.

Los campos de anteriores de “Amenaza (Descripción)”, “Tipo Amenaza” y “Fuente Amenaza”, se pueden obtener desde el Anexo N°1 del presente procedimiento.

Respecto a la valorización de la amenaza, como se indica en la definición de los campos, podemos utilizar la siguiente escala, y uso de criterios para establecer su valor.

Orientación de valores de amenazas		
Categoría	Valor	Criterio de Evaluación
Muy Alto	5	- El adversario tiene un nivel de experiencia muy sofisticado, cuenta con buenos recursos y que capacidades que puede generar oportunidades para soportar múltiples ataques exitosos, continuos y coordinados. - El adversario busca obstaculizar gravemente o destruir la función principal del negocio, explotando los sistemas de información de la organización o infraestructura. - Los efectos del tercero, error, accidente o acto de la naturaleza son devastadores e involucran a prácticamente todos los usuarios, sistemas, infraestructura y /o servicios de la organización.
Alto	4	- El adversario tiene un nivel sofisticado de experiencia, con capacidades y oportunidades para soportar múltiples ataques coordinados exitosos - El adversario busca impedir aspectos críticos de una función principal del negocio o colocarse en una posición para hacerlo en el futuro, manteniendo una presencia en los sistemas de información o la infraestructura de la organización. - Los efectos del tercero, error, accidente o acto de la naturaleza son extensos e involucran a la mayoría de los usuarios, sistemas, infraestructura y /o servicios de la organización.
Medio	3	- El adversario tiene recursos, experiencia y oportunidades moderados para respaldar múltiples ataques. - El adversario busca obtener o modificar información crítica o sensible específica o usurpar los recursos cibernéticos de la organización estableciendo un punto de apoyo en la información de la organización sistemas o infraestructura. - Los efectos del tercero, error, accidente o acto de la naturaleza son de amplio alcance e involucran una parte significativa de los usuarios, sistemas, infraestructura y /o servicios de la organización.
Bajo	2	- El adversario tiene recursos, experiencia y oportunidades limitados para respaldar un ataque exitoso. - El adversario busca activamente obtener información crítica o sensible, interrumpiendo el uso de recursos cibernéticos de la organización, y lo hace sin preocuparse por la detección. - Los efectos del tercero, error, accidente o acto de la naturaleza son limitados e involucran a algunos de los usuarios, sistemas, infraestructura y /o servicios de la organización.

Muy Bajo	1	- El adversario tiene recursos, experiencia y oportunidades muy limitados para respaldar un ataque. - El adversario busca usurpar, interrumpir o desfigurar los recursos cibernéticos de la organización, y lo hace sin preocuparse por la detección de ataques. - Los efectos del tercero, error, accidente o acto de la naturaleza son mínimos, y afectan a pocos o ninguno de los usuarios, sistemas, infraestructura y /o servicios de la organización.
----------	---	--

6.4.2.4 Identificación de Vulnerabilidades.

Se debe identificar las vulnerabilidades que pueden ser explotadas por las amenazas para causar daños a los activos o a la institución. La sola presencia de una vulnerabilidad no causa daño por sí misma, dado que es necesario que haya una amenaza presente para explotarla.

Una vulnerabilidad que no tiene una amenaza correspondiente puede no requerir de la implementación de un control, pero es recomendable reconocerla y monitorearla para determinar los cambios.

Ejemplo identificación de vulnerabilidades

Análisis de Riesgos				
Proceso /Subproceso	# Activo	Nombre Activo	Amenaza	Vulnerabilidad
Infraestructura	1	Red Datos	Indisponibilidad de servicios	Red de datos mixta (cat.5e, 6a)
	2	Firewall	Acceso no deseado a activos críticos	imposibilidad de actualizar firmware por falta de recursos del equipo
			Indisponibilidad de servicios	Inexistencia de equipo de redundancia

La identificación de amenazas se debe generar con un listado que considere.

- Vulnerabilidad (Descripción): Descripción de la vulnerabilidad relacionada con el activo de información.
- Valor Vulnerabilidad: Se debe ingresar un valor cuantitativo para la vulnerabilidad descrita, con el objeto de valorar su incidencia sobre el activo según criterio expuesto a continuación.
- Nivel Vulnerabilidad: Se debe ingresar un valor cualitativo para la vulnerabilidad descrita, con el objeto de valorar su incidencia sobre el activo según criterio expuesto a continuación.

Para la valorización de las vulnerabilidades, podemos utilizar la siguiente escala, y uso de criterios para establecer su valor.

Orientación de valores de vulnerabilidades		
Categoría	Valor	Criterio de Evaluación
Muy Alto	5	La vulnerabilidad está expuesta y es explotable, y su explotación podría resultar en impactos severos. - Es casi certeza que un tercero, error, accidente o acto de la naturaleza pueda explotar esta vulnerabilidad diariamente.

Alto	4	- La vulnerabilidad es de gran preocupación, basada en la exposición de la vulnerabilidad y la facilidad de explotación y / o sobre la gravedad de los impactos que pudieran resultar de su explotación. - Es muy probable que un tercero, un error, accidente o acto de la naturaleza pueda explotar esta vulnerabilidad mensualmente.
Medio	3	- La vulnerabilidad es una preocupación moderada, basada en la exposición de la vulnerabilidad y la facilidad de explotación y / o sobre la gravedad de los impactos que pudieran resultar de su explotación. - Es algo probable que un tercero, un error, accidente o acto de la naturaleza pueda explotar esta vulnerabilidad al menos una vez por año.
Bajo	2	- La vulnerabilidad es una preocupación menor, pero la efectividad de la remediación podría mejorarse. - Es improbable que un tercero, un error, accidente o acto de la naturaleza pueda explotar esta vulnerabilidad al menos una vez en los últimos 5 año.
Muy Bajo	1	- La vulnerabilidad no es motivo de preocupación. -Es muy improbable que un tercero, un error, accidente o acto de la naturaleza pueda explotar esta vulnerabilidad u ocurre después de cada 5 años o más.

Un listado de vulnerabilidades para tener presentes, son incluidas en el Anexo N° 2 “Ejemplo de Vulnerabilidades” de este procedimiento, que se refiere a la NCh-ISO/IEC 27.005:2020 en su anexo D, D.1.

6.4.2.5 Establecimiento del Nivel de Probabilidad

La probabilidad refiere a la posibilidad de que se materialice un riesgo, cuando una amenaza explota una vulnerabilidad, afectando consigo el posible cumplimiento de un objetivo, continuidad de un servicio o su eficiencia, se debe indicar el nivel de probabilidad para cada riesgo identificado, considerando la medición de su amenaza y vulnerabilidad.

- Nivel de Probabilidad: El registro del nivel de probabilidad, es sujeto a criterio del evaluador, debiendo observar el valor y nivel de la amenaza y su vulnerabilidad, los criterios para establecer este nivel de probabilidad se definen de la siguiente forma.

ORIENTACIÓN DE VALORES DE PROBABILIDAD		
Nivel	Valor	Descripción de Probabilidad
Muy improbable	1	Riesgo cuya probabilidad de ocurrencia es muy baja, es decir, se tiene entre 1% a 10% de seguridad que éste se presente en el año en curso
Improbable	2	Riesgo cuya probabilidad de ocurrencia es baja, es decir, se tiene entre 11% a 30% de seguridad que éste se presente en el año en curso.
Moderado	3	Riesgo cuya probabilidad de ocurrencia es media, es decir, se tiene entre 31% a 65% de seguridad que éste se presente en el año en curso.
Probable	4	Riesgo cuya probabilidad de ocurrencia es alta, es decir, se tiene entre 66% a 89% de seguridad que éste se presente en el año en curso.
Casi certeza	5	Riesgo cuya probabilidad de ocurrencia es muy alta, es decir, se tiene un alto grado de seguridad que éste se presente en el año en curso. (90% a 100%)

El registro en el campo señalado debe ser dual, considerando el valor y su nivel por ejemplo “3. Moderado” o “2. Improbable”.

6.4.3 Evaluación del Riesgo.

La evaluación del riesgo debe incluir los atributos de la seguridad de la información y su protección, considerando la medición de amenazas y vulnerabilidades, además de su probabilidad de materialización. Para una evaluación eficiente debemos conocer las consecuencias en distintas dimensiones tal como son revisadas a continuación.

6.4.3.1 Identificación de Consecuencias.

Según la NCh-ISO 27005:2020, se debe utilizar el concepto de impacto del negocio para medir las consecuencias, como nuestro alcance nos fija una determinación para un SGSI, con la consideración que estamos revisando la gestión de riesgos en una institución pública, debemos atender para nuestro caso las siguientes dimensiones a ser registradas para cada activo.

- Impacto Financiero: pérdidas financieras; recursos financieros necesarios para reemplazar o reparar un activo se habrían utilizado en otro lugar.
- Impacto Operacional: Se deben registrar el o los impactos a los servicios, disponibilidad de recursos operativos de la institución, considerando una eventual materialización del riesgo.
- Impacto Reputacional/Político: Se debe observar y registrar el impacto en la reputación del servicio, revisando escenarios como, por ejemplo, la credibilidad, el profesionalismo, la responsabilidad y la buena imagen de la institución, que pueda verse afectada respecto al riesgo.
- Impacto Normativo: Se debe registrar el impacto normativo, las consecuencias de no cumplir con las normas establecidas, incluyendo leyes y decretos oficiales.

6.4.3.2 Evaluación de Impacto.

Se debe evaluar el impacto en los servicios asociados a cada activo de información evaluado, y que puede resultar de los incidentes de seguridad de la información, ya sean posibles al corto plazo, o materializados a futuro, teniendo siempre en consideración las consecuencias a una violación de la seguridad de la información, como por ejemplo la pérdida de la confidencialidad, integridad o la disponibilidad de los activos de información.

Para esta evaluación se debe considerar el análisis de los escenarios identificados de incidentes relevantes, incluyendo la identificación de amenazas, vulnerabilidades, activos de información, sus consecuencias, y los procesos de negocio relacionados.

- **Nivel de Impacto:** Para el registro del impacto se deben considerar además la probabilidad de ocurrencia de incidente de seguridad de la información, para esto se debe tener en cuenta el análisis relacionado con los activos de información, las amenazas y vulnerabilidades, incluyendo la afección a los procesos. Los criterios para establecer este nivel de probabilidad se definen de la siguiente forma.

Categoría	Valor	Financiero	Operacional	Reputacional	Normativo
Catastrófico	5	Riesgo cuya materialización puede generar pérdidas financieras (\$) que tendrán un impacto catastrófico en la organización y/o comprometen totalmente la imagen de la organización.	- Suspensión de operaciones claves generalizada por más de 4 horas - Pérdida de operación en más del 50% de los procesos claves - Pérdida de continuidad operativa en procesos claves o de soporte,	- Cobertura negativa generalizada en medios masivos y redes sociales (>=1 semana) - Comentarios negativos de Stakeholders claves - Comentarios negativos a nivel sectorial - Caída en las acciones (>10%) - Pérdida de empleados (>10%)	- Riesgo de incumplimiento muy alto con reguladores y/o clientes con consecuencias muy graves en caso de incumplimiento (sanciones económicas, cese definitivo, pérdida de licencia, restricción financiera, juicios). - Resolución judicial con determinación

Categoría	Valor	Financiero	Operacional	Reputacional	Normativo
			superando el RTO establecido.	- Pérdida de clientes (>10%)	de sanciones y multas. -Multas o costos superiores a \$25.000.000
Mayores	4	Riesgo cuya materialización puede generar pérdidas financieras (\$) que tendrán un impacto importante en la organización y/o comprometen fuertemente la imagen de la organización.	- Suspensión de operaciones claves generalizada por más de 2 horas - Pérdida de operación en más del 30% de los procesos claves - Pérdida de continuidad operativa en procesos claves o de soporte, superando el RTO establecido.	- Cobertura negativa generalizada en medios masivos y redes sociales (Entre 6 a 3 días) - Comentarios negativos de Stakeholders - Comentarios negativos a nivel empresarial - Caída en las acciones (Entre un 5% y 10%) - Pérdida de empleados (Entre un 5% y 10%) - Pérdida de clientes (Entre un 5% y un 10%)	- Riesgo de incumplimiento alto con reguladores y/o clientes con consecuencias graves en caso de incumplimiento (sanciones económicas, cese definitivo, pérdida de licencia, restricción financiera, juicio, sanciones administrativas). - Resolución judicial con determinación de sanciones y multas. -Multas o costos entre \$10.000.000 y hasta \$25.000.000
Moderadas	3	Riesgo cuya materialización puede generar pérdidas financieras (\$) que tendrán un impacto moderado en la organización y/o comprometen moderadamente la imagen de la organización	- Suspensión de operaciones claves generalizada por más de 1 horas - Pérdida de operación en más del 10% de los procesos claves - Pérdida de continuidad operativa en procesos claves o de soporte, superando el RTO establecido.	- Cobertura negativa generalizada en medios masivos y redes sociales (Entre 2 a 3 días) - Caída en las acciones (Entre un 2% y 4%) - Pérdida de empleados (Entre un 2% y 4%) - Pérdida de clientes (Entre un 2% y un 4%)	- Riesgo de incumplimiento con reguladores y/o clientes con consecuencias en oficios o reclamos formales - Procesos judiciales o prejudiciales con potencial de acuerdo -Multas o costo entre \$2.000.000 y hasta \$5.000.000
Menores	2	Riesgo cuya materialización puede generar pérdidas financieras (\$) que tendrán un impacto menor en la organización y/o comprometen de forma menor la imagen de la organización	- Pérdida de operación en menos del 10% de los procesos claves - Suspensión de operaciones de procesos de soporte por más de 1 horas - Pérdida de continuidad operativa en procesos de soporte, superando el RTO establecido.	- Cobertura aislada y menciones esporádicas en medios masivos y redes sociales (menor a 2 días) - Caída en las acciones (Menor al 2%) - Pérdida de empleados (Menor al 2%) - Pérdida de clientes (Menor al 2%)	- Riesgo de incumplimiento con reguladores y/o clientes con consecuencias en amonestaciones formales o reclamos informales - Acuerdos formales de reparación dentro de lo establecido en regulación o contractualmente -Multas o costos menor a \$2.000.000

Categoría	Valor	Financiero	Operacional	Reputacional	Normativo
Insignifican tes	1	Riesgo cuya materialización no genera pérdidas financieras (\$) ni compromete de ninguna forma la imagen de la organización.	- Suspensión de operaciones de procesos de soporte por menos de 1 hora - Pérdida de continuidad operativa en procesos de soporte, superando el RTO establecido.	- Cobertura negativa limitada en redes sociales (escasos comentarios), sin menciones en otros medios masivos.	- Riesgo de incumplimiento sin efectos en reguladores o clientes. - Sin multa o costo económico relacionado.

El registro en el campo señalado debe ser dual, considerando el valor y su nivel por ejemplo “5. Catastrófico” o “1. Insignificante”.

6.4.3.3 Riesgo Inherente.

Para la determinación del riesgo inherente, se trata de determinar los niveles de severidad a través de la combinación entre la probabilidad y el impacto. Se definen 4 zonas de severidad en la matriz de calor.

Esta definición es soportada con las siguientes estructuras de medición y escalas, según lo establecido en el punto de “establecimiento de la probabilidad” y la “evaluación de impacto”, ambas escalas resumidas a continuación:

Escala de probabilidad impacto				
Valorización nivel/valor				
Probabilidad		Impacto		
Muy improbable	1	Insignificante	1	
Improbable	2	Menor	2	
Moderada	3	Moderado	3	
Probable	4	Mayor	4	
Casi certeza	5	Catastrófico	5	

El producto de la probabilidad de ocurrencia de una amenaza, la probabilidad de ocurrencia de vulnerabilidades, se obtienen como resultado el nivel de riesgo de cada activo. Luego cada combinación del valor de la probabilidad e impacto, quedará establecida entre un rango de valores desde 1 a 25, por lo que estableceremos el valor de severidad del riesgo por medio de un mapa de calor. La institución, podrá establecer la escala de mapa de calor para determinar el riesgo, de acuerdo con el siguiente ejemplo mapa de calor:

MAPA DE CALOR APETITO DEL RIESGO						
RIESGO EVALUADO SEGÚN SEVERIDAD		PROBABILIDAD				
		MUY IMPROBABLE 1	IMPROBABLE 2	MODERADA 3	PROBABLE 4	CASI CERTEZA 5
IMPACTO	CATASTRÓFICO: 5	5	10	15	20	25
	MAYOR: 4	4	8	12	16	20
	MODERADO: 3	3	6	9	12	15
	MENOR: 2	2	4	6	8	10
	INSIGNIFICANTE: 1	1	2	3	4	5

Conocidas las escalas de medición, considerando el apetito del riesgo de la institución, debemos registrar los valores del riesgo inherente.

- **Valor de Severidad del Riesgo:** Corresponde al producto calculado entre la probabilidad e impacto de las amenazas, vulnerabilidades y consecuencias de un riesgo sobre un activo.
- **Nivel de Severidad:** Corresponde al nivel asignado, según rango del valor de la severidad determinada.

6.5 **TRATAMIENTO DEL RIESGO.**

El tratamiento de los riesgos es tomar decisiones frente a los diferentes riesgos existentes de acuerdo con la estrategia de la institución. Las opciones para el tratamiento del riesgo se deberían seleccionar con base en el resultado de la valoración del riesgo, el costo esperado para implementar estas opciones y los beneficios esperados como resultado de tales opciones.

Se deben seleccionar controles para reducir, aceptar/retener, evitar o transferir los riesgos y se debe definir un plan para el tratamiento del riesgo.

Existen cuatro opciones disponibles para el tratamiento del riesgo:

- **Reducción del riesgo:** Se debe reducir mediante la selección de controles, de manera tal que el riesgo residual se pueda reevaluar como aceptable
- **Aceptación del riesgo:** La decisión sobre la retención del riesgo sin acción posterior se debería tomar dependiendo de la evaluación del riesgo.
- **Evitación del riesgo:** Se debe evitar la actividad o la acción que da origen al riesgo particular.
- **Transferencia del riesgo:** El riesgo se debe transferir a otra parte que pueda gestionar de manera más eficaz el riesgo particular dependiendo de la evaluación del riesgo

6.6 **ACEPTACIÓN DEL RIESGO**

Se deber tomar la decisión de aceptar los riesgos y las responsabilidades de la decisión, y registrarla de manera formal.

Esta opción se toma cuando los costos de implementación de un control de seguridad sobrepasan el valor del activo de información que se desea proteger o cuando el nivel del riesgo es muy bajo, en ambos casos la organización asume los daños provocados por la materialización del riesgo.

Durante el desarrollo, se deberían considerar los siguientes aspectos:

- *Los criterios de aceptación del riesgo pueden incluir umbrales múltiples*, con una meta de nivel de riesgo deseable, pero con disposiciones para que la alta dirección acepte los riesgos por encima de este nivel, en circunstancias definidas.
- Los criterios de aceptación del riesgo se pueden expresar como la relación entre el beneficio estimado (u otros beneficios del negocio) y el riesgo estimado.
- Los diferentes criterios de aceptación del riesgo se pueden aplicar a diferentes clases de riesgos, por ejemplo, los riesgos que podrían resultar en incumplimiento con reglamentos o leyes, podrían no ser aceptados, aunque se puede permitir la aceptación de riesgos altos, si esto se especifica como un requisito contractual.
- Los criterios de aceptación del riesgo pueden incluir requisitos para tratamiento adicional en el futuro, por ejemplo, se puede aceptar un riesgo si existe aprobación y compromiso para ejecutar acciones que reduzcan dicho riesgo hasta un nivel aceptable en un periodo definido de tiempo

6.6.1.1 Identificación de Controles Existentes.

Se debe mantener un listado de controles a implementar, según planificaciones, actividades, y establecimientos de la norma NCh-ISO/IEC 27.001 de sistemas de gestión de seguridad de la información (requisitos), si bien deben ser considerados los controles propuestos por el anexo A de la mencionada norma, según sus objetivos de control y referencias, se deben generar controles adicionales que permitan complementar estas recomendaciones.

Para cada control, se debería considerar

- Un identificador.
- Nombre del control.
- Descripción del control.

Para efectos de esta evaluación de riesgos, es totalmente factible considerar los controles listados en la norma ISO/IEC 27.001:2013 anexo A (normativo), estos corresponden a un total de 114 agrupados en 14 dominios.

6.6.1.2 Plan de Tratamiento

Para el tratamiento del riesgo se debe determinar la opción de tratamiento y control, por lo que el registro de esta información se definirá para cada activo y su riesgo.

- Opción de Tratamiento: Se debe registrar la opción de tratamiento para cada riesgo, indicando si el riesgo se va a “reducir”, “retener”, “evitar” o “compartir”.
- Controles Aplicados NCh-ISO 27001.Of2013: Se deben registrar los controles de la norma señalada, como medida de gestión del riesgo para el tratamiento señalado.

6.6.1.3 Efectividad del Control.

Para cada activo, su riesgo evaluado y tratado, se debe registrar la efectividad de su control, considerando los siguientes campos.

- Oportunidad: Se debe registrar si la oportunidad del control es de aplicación preventiva, correctiva o detectiva.
- Periodicidad: Se debe registrar si la periodicidad del control es de forma permanente, periódica u ocasional.
- Automatización: Se debe registrar si la automatización del control es de forma automática, semi automática o manual.

Oportunidad de Aplicación	Periodicidad de Aplicación	Automatización del Control
Preventivo	Permanente	Automatizado
Correctivo	Periódico	Semi-automatizado
Detectivo	Ocasional	Manual

La efectividad del control y la exposición al riesgo, podrán ser medidos cualitativamente, esta medición es a criterio del evaluador, donde define la efectividad, observando los factores de oportunidad, periodicidad y automatización, deduciendo el efectividad y exposición.

6.6.1.4 Madurez.

Se debe registrar la madurez de la efectividad del control considerando el registro de los siguientes campos.

- Nivel de Madurez: Se debe clasificar el nivel de madurez de control, respecto al porcentaje de exposición al riesgo, donde se asignará un nivel según criterio de la siguiente tabla, se debe considerar el porcentaje dentro del campo rango.

Niveles de madurez	Rango	Detalle
1. Inicial	0%	No aplicable: no evaluado
2. Repetible	0% - 35%	Pobre: inexistente, inapropiado, ineficaz, inadecuado, irrelevante.
3. Definido	36% - 65%	Insuficiente: informal, no escrito, esporádico, parcial, en proceso.
4. Gestionado	66% - 85%	Aceptable: implementado, cumplido, en práctica, hecho, preparado, completo.
5. Optimizado	86% - 100%	Sobresaliente: superior, ejemplar, de clase mundial, el mejor de su clase.

- Solidez del Control: Se debe clasificar la solidez del control, respecto al porcentaje de efectividad del control, donde se asignará un nivel según criterio de la siguiente tabla, se debe considerar el porcentaje dentro del campo rango.

Clasificación de solidez del control	Rango	Nivel de influencia en la probabilidad	Nivel de influencia en el impacto
Débil	0% - 49%	0	0
Moderado	50% - 99%	2	1
Fuerte	100%	3	2

6.6.1.5 Evaluación del Riesgo Residual.

Para efectos de medición del riesgo residual, utilizaremos las mismas mediciones, escalas y criterios que son utilizados para el riesgo inherente, la diferencia radica en que para la evaluación se deben considerar las mediciones del nivel de madurez y la solidez del control, observando la eficiencia de esas mediciones, aplicaremos según criterio una asignación de valor según la siguiente escala.

Escala de probabilidad impacto			
Valorización nivel/valor			
Probabilidad		Impacto	
Muy improbable	1	Insignificante	1
Improbable	2	Menor	2
Moderada	3	Moderado	3
Probable	4	Mayor	4
Casi certeza	5	Catastrófico	5

- Probabilidad: Se debe registrar la probabilidad de ocurrencia del riesgo tratado, considerando los nuevos escenarios de madurez definidos para el tratamiento del riesgo (Nivel de Madurez y Solidez del Control).
- Impacto: Se debe registrar impacto del riesgo tratado, considerando los nuevos escenarios de madurez definidos para el tratamiento del riesgo (Nivel de Madurez y Solidez del Control).
- Valor del Riesgo Residual: El valor del riesgo residual viene dado por el valor de la probabilidad e impacto obtenidos una vez observado el nivel de madurez y solidez del control, en las actividades de tratamiento del riesgo.
- Riesgo Residual: El riesgo residual se obtiene del producto de la probabilidad e impacto definidos en el valor del riesgo residual, el cual debe ser clasificado según la tabla a continuación de la misma forma que el riesgo inherente.

6.7 COMUNICACIÓN DE LOS RIESGOS

La información acerca de los riesgos de seguridad de la información, se deben intercambiar y/o compartir entre quienes toman las decisiones y las partes involucradas de la institución.

La comunicación del riesgo se deberá realizar con el fin de lograr lo siguiente:

- Proporcionar seguridad del resultado de la gestión del riesgo de la institución.
- Recolectar información del riesgo.
- Compartir los resultados de la valoración del riesgo y presentar el plan para el tratamiento del riesgo.
- Evitar o reducir tanto la ocurrencia como la consecuencia de las brechas de seguridad de la información debido a la falta de entendimiento entre quienes toman las decisiones y las partes involucradas.
- Brindar soporte para la toma de decisiones.
- Obtener conocimientos nuevos sobre la seguridad de la información.
- Coordinar con otras partes y planificar las respuestas para reducir las consecuencias de cualquier incidente.
- Dar a quienes toman las decisiones y a las partes involucradas un sentido de responsabilidad acerca de los riesgos.
- Mejorar la toma de conciencia.

La coordinación entre las personas principales que toman las decisiones y las partes involucradas se puede lograr en el Comité de Seguridad de la Información (CSI) en el cual pueda tener lugar el debate acerca de los riesgos, su prioridad, el tratamiento adecuado y la aceptación.

6.8 MONITOREO Y REVISIÓN

El proceso de gestión del riesgo en la seguridad de la información se debe monitorear, revisar y mejorar continuamente, según sea necesario y adecuado.

La organización debe garantizar que el proceso de gestión del riesgo de la seguridad de la información y las actividades relacionadas aún son adecuadas en las circunstancias actuales y se cumplen.

Todas las mejoras acordadas para el proceso o las acciones necesarias para mejorar la conformidad con el proceso se deberían notificar al Comité de Seguridad de la Información, para tener seguridad de que no se omite ni subestima ningún riesgo o elemento del riesgo, y que se toman las acciones necesarias y las decisiones para brindar una comprensión realista del riesgo y la capacidad para responder.

6.9 VALIDACIÓN Y TRATAMIENTO

- El Oficial de seguridad de la información será responsable de un primer nivel de validación del análisis de riesgos realizado por todos los responsables de las distintas áreas.
- Una segunda validación será dada por la aceptación de la responsabilidad por el riesgo actual, la cual se realizará por los propietarios de los riesgos, dando por aprobada la matriz final y el informe de análisis de riesgos y el plan de tratamiento.
- El seguimiento de los planes de tratamiento se realizará por el Oficial de seguridad de la información y en los casos que sea necesario también del Comité de SGSI. El avance de todos los planes de tratamiento es registrado por sus responsables en la planilla elaborada para tal fin.

7 **REGISTROS**

- Matriz de riesgos de seguridad de la información de la institución
- Informe análisis de riesgos y plan de tratamientos
- Acta de aprobación de la matriz de riesgo de seguridad

8 **DIFUSION**

La comunicación del presente procedimiento se efectuará de manera que el contenido de la documentación sea accesible y comprensible para todos los usuarios, a lo menos se deberá hacer difusión mediante los siguientes canales:

- Publicación en sitioweb de Minsal http://www.minsal.cl/seguridad_de_la_informacion/
- Publicación en la intranet de Minsal <http://isalud.minsal.cl/>
- Correo informativo.

9 **REVISION Y MEDICION**

La revisión del contenido de este Procedimiento se efectuará a lo menos cada dos años por el Comité de Seguridad de la Información, o atendiendo necesidades de cambios para garantizar su idoneidad, adecuación y efectividad.

10 **CONTROL DE VERSIONES**

Versión	Fecha	Creado por	Pág. o Sección modificada	Descripción de la modificación
1	Junio 2023	Pablo Fabres	Todo el documento	Creación del documento

11 **REFERENCIAS**

[1]. SITIO WEB MINSAL – Política General de Seguridad de la Información – https://www.minsal.cl/seguridad_de_la_informacion/

[2]. SITIO INTRANET MINSAL – Procedimiento de Riesgos de Seguridad de la Información – <http://isalud.minsal.cl/ministerio/dgstic/SGSI/Paginas/default.aspx>

[3] SITIO WEB_– Definición de riesgo fuente – <https://dle.rae.es/riesgo>

12 ANEXOS

ANEXO 1 – Informativo Ejemplos de Amenazas Típicas.

El presente anexo entrega ejemplos de amenazas típicas determinadas por la ISO indicada. Cabe mencionar que el campo “Origen” viene considerando valores A, D y E, los que corresponden a.

- A: Acción accidental, refiere a todas las acciones humanas.
- D: Acción deliberada, refiere a todas las acciones deliberadas.
- E: Acción del entorno, refiere a todos los incidentes que no se basan en acciones humanas.

Tipo	Amenazas	Origen
Daño físico	Incendio	A, D, E
	Daños por agua	A, D, E
	Contaminación	A, D, E
	Accidente grave	A, D, E
	Destrucción de equipo o medios	A, D, E
	Polvo, corrosión, congelamiento	A, D, E
Eventos naturales	Fenómeno climático	E
	Fenómeno sísmico	E
	Fenómeno volcánico	E
	Fenómeno meteorológico	E
	Inundación	E
Pérdida de servicios esenciales	Falla de sistema de aire acondicionado o suministro de agua	A, D
	Pérdida de suministro eléctrico	A, D, E
	Falla de equipo de telecomunicaciones	A, D
Perturbaciones debido a radiación	Radiación electromagnética	A, D, E
	Radiación térmica	A, D, E
	Pulsos electromagnéticos	A, D, E

Tipo	Amenazas	Origen
Compromiso de la información	Interceptación de señales de interferencia comprometedoras	D
	Espionaje remoto	D
	Escuchas a escondidas	D
	Robo de documentos o medios	D
	Robo de equipo	D
	Recuperación de medios reciclados o desechados	D
	Divulgación	A, D
	Datos de fuentes no confiables	A, D
	Alteración de hardware	D
	Alteración de software	A, D
	Detección de ubicación	D
Fallas técnicas	Falla de equipo	A
	Mal funcionamiento de equipo	A
	Saturación del sistema de información	A, D
	Mal funcionamiento de software	A
	Violación de mantenibilidad del sistema de información	A, D
Acciones no autorizadas	Uso de equipo no autorizado	D
	Copia fraudulenta de software	D
	Uso de software falsificado o copiado	A, D
	Corrupción de los datos	D
	Procesamiento ilegal de los datos	D
Comprometimiento de funciones	Error de uso	A
	Abuso de derechos	A, D
	Falsificación derechos	D
	Negación de acciones	D
	Violación de disponibilidad de personal	A, D, E

ANEXO 2 Ejemplos de Vulnerabilidades.

El presente anexo entrega ejemplos de vulnerabilidades determinadas por la ISO indicada.

Tipos	Ejemplos de vulnerabilidades	Ejemplos de amenazas
Hardware	Mantenimiento insuficiente/instalación defectuosa de medios de almacenamiento	Violación de mantenibilidad del sistema de información
	Falta de esquemas de reemplazo periódico	Destrucción de equipo o medios
	Susceptibilidad a humedad, polvo, tierra	Polvo, corrosión, congelamiento
	Sensibilidad a radiación electromagnética	Radiación electromagnética
	Falta de configuración eficiente de control de cambio	Error de uso
	Susceptibilidad a variaciones de voltaje	Pérdida de suministro de energía
	Susceptibilidad a variaciones de temperatura	Fenómeno meteorológico
	Almacenamiento desprotegido	Robo de medios o documentos
	Falta de cuidado en el desecho	Robo de medios o documentos
	Copia no controlada	Robo de medios o documentos
Software	Ensayo de software insuficiente o inexistente	Abuso de derechos
	Falencias bien conocidas en el software	Abuso de derechos
	No "salida de sesión" cuando se deja la estación de trabajo	Abuso de derechos
	Eliminación o reutilización de medios de almacenamiento sin borrado adecuado	Abuso de derechos
	Falta de rastreo de auditoría	Abuso de derechos
	Asignación errónea de derechos de acceso	Abuso de derechos
	Software ampliamente distribuido	Corrupción de datos
	Aplicar programas de aplicación a los datos equivocados en términos de tiempo	Corrupción de datos
	Interfaz de uso complicado	Error de uso
	Falta de documentación	Error de uso
	Configuración de parámetro incorrecta	Error de uso
	Fechas incorrectas	Error de uso

Tipos	Ejemplos de vulnerabilidades	Ejemplos de amenazas
	Falta de mecanismo de identificación o autenticación como autenticación del usuario	Falsificación de derechos
	Tablas de contraseñas no protegidas	Falsificación de derechos
	Gestión de contraseñas mediocre	Falsificación de derechos
	Servicios innecesarios activados	Procesamiento ilegal de datos
	Software inmaduro o nuevo	Mal funcionamiento de software
	Especificaciones para desarrolladores poco claras o incompletas	Mal funcionamiento de software
	Falta de control de cambio eficaz	Mal funcionamiento de software
	Descarga y uso de software sin control	Alteración de software
	Falta de copias de respaldo	Alteración de software
	Falta de protección física del edificio, puertas y ventanas	Robo de medios o documentos
	Falla para producir informes de gestión	Uso de equipo no autorizado
Red	Falta de evidencia de envío o recepción de un mensaje	Negación de acciones
	Lineas de comunicación sin protección	Escucha a escondidas
	Tráfico sensible sin protección	Escucha a escondidas
	Cableado de conexión deficiente	Falla de equipo de telecomunicaciones
	Punto único de falla	Falla de equipo de telecomunicaciones
	Falta de identificación y autenticación de remitente o receptor	Falsificación de derechos
	Arquitectura de red insegura	Espionaje remoto
	Transferencia de contraseñas de forma evidente	Espionaje remoto
	Gestión de red no adecuada (resiliencia de ruta)	Saturación del sistema de información
	Conexiones de red pública no protegidas	Uso de equipo no autorizado
Personal	Ausencia de personal	Violación de disponibilidad de personal
	Procedimientos de reclutamiento inadecuados	Destrucción de equipo o medios
	Capacitación de seguridad insuficiente	Error de uso
	Uso incorrecto de software y hardware	Error de uso
	Falta de concientización de seguridad	Error de uso
	Falta de mecanismos de seguimiento	Procesamiento ilegal de datos
	Trabajo no supervisado que realiza personal externo o de limpieza	Robo de medios o documentos
	Falta de políticas para el uso correcto de medios de telecomunicaciones y mensajería	Uso de equipo no autorizado
Sitio	Uso inadecuado o descuidado de control de acceso físico a edificios o habitaciones	Destrucción de equipo o medios
	Ubicación en un área susceptible de inundación	Inundación
	Red de energía eléctrica inestable	Pérdida de suministro de energía
	Falta de protección física del edificio, puertas y ventanas	Robo de equipo

Tipos	Ejemplos de vulnerabilidades	Ejemplos de amenazas
Ordenamiento	Falta de procedimiento formal para el registro de usuarios y anulación de registro	Abuso de derechos
	Falta de proceso formal para revisión de derecho de acceso (supervisión)	Abuso de derechos
	Provisiones insuficientes o falta de ellas (relacionadas con seguridad) en contratos con clientes y/o terceras partes	Abuso de derechos
	Falta de procedimiento de seguimiento de las instalaciones de procesamiento de información	Abuso de derechos
	Falta de auditorías regulares (supervisión)	Abuso de derechos
	Falta de procedimientos de identificación y evaluación de riesgos	Abuso de derechos
	Falta de informes de fallas registrados en las sesiones de administrador y operador	Abuso de derechos
	Respuesta inadecuada de mantenimiento de servicio	Violación de la mantenibilidad del sistema de información
	Falta o insuficiencia de Acuerdo de Prestación de Servicio	Violación de la mantenibilidad del sistema de información
	Falta de procedimiento de control de cambio	Violación de la mantenibilidad del sistema de información
	Falta de procedimiento formal para control de documentación de SGSI	Corrupción de datos
	Falta de procedimiento formal para supervisión de registros de SGSI	Corrupción de datos
	Falta de proceso formal para autorización de información pública disponible	Datos de fuentes no confiables
	Falta de asignación adecuada de responsabilidades de seguridad de la información	Negación de acciones
	Falta de planes de continuidad	Falla de equipo
	Falta de política de uso de correos electrónicos	Error de uso
	Falta de procedimientos para introducir software en sistemas de operación	Error de uso
	Falta de registros de las sesiones de administrador y operador	Error de uso
	Falta de procedimientos para manejo de información clasificada	Error de uso
	Falta de responsabilidades de seguridad de la información en las descripciones de empleo	Error de uso
	Falta o insuficiencia de provisiones (relacionadas con seguridad de la información) en contratos de empleados	Procesamiento ilegal de datos
	Falta de un proceso disciplinario definido en caso de incidente de seguridad de la información	Robo de equipo
	Falta de política formal sobre el uso de computadores portátiles	Robo de equipo
	Falta de control de activos fuera de la instalación	Robo de equipo
	Falta o insuficiencia de política de "escritorio y pantalla limpios"	Robo de medios o documentos
	Falta de autorización de instalaciones procesadoras de información	Robo de medios o documentos
	Falta de mecanismos de seguimientos establecidos para violaciones de seguridad	Robo de medios o documentos
	Falta de revisiones por la gerencia regulares	Uso no autorizado de equipo
	Falta de procedimientos para informar debilidades de seguridad	Uso no autorizado de equipo
	Falta de procedimientos de cumplimiento de provisiones con derechos intelectuales	Uso de software copiado o falsificado